

How To Own Every User On A Social Networking Site

How To Own Every User On A Social Networking Site - Author not stated, blog.whitehatsec.com.

- Published: date not stated
- Original: <<https://blog.whitehatsec.com/how-to-own-every-user-on-a-social-networking-site/>>
- Preserved from: <https://blog.whitehatsec.com/how-to-own-every-user-on-a-social-networking-site/> (stored) on 2026-08-06
- Capture timestamp: 20150528150919
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Top 10 Web Hacking Techniques lists, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

How to Own Every User on a Social Networking Site: ** **DOM-Based Persistent XSS Paired With Insufficient Authorization

While performing business logic assessments of our clients' Web applications we find numerous vulnerabilities on a daily basis. What sets these manual assessments apart from the single vulnerability identification process is that hands-on assessments have the ability to gain so much control of an application. In the example presented here we will see how the pairing of two high-risk vulnerabilities can result in an infinitely higher threat to this application and its users.

NOTE: Although I found the following vulnerability scenario on one of our client's applications, I've stripped all of the identifying material, while still preserving, I hope, the severity of the findings and the technical specifics.

<http://www.FAKESITE.com/profile.aspx?id=123BASE64VALUE456%3d%3d>

Let's say that FAKESITE.com is a social networking site with millions of users, each having a unique profile and id.

The above URL would be an example of the public profile URL of every registered user, and the id is a base64 encoded value of some encrypted id interpreted on the server side, with no sensitive information leaked by de-encoding it.

On their profile, users can add keywords or 'tags,' and these profiles can then be used as identifiers that other users of the site can use to do searches. For example, if I'm a rock climber who plays guitar and loves unicorns, I could add the tags: rock climbing, guitar, unicorns.

The POST request to perform this action of adding tags looks like this:

POST /profile.aspx/AddTag HTTP/1.1 Host: www.FAKESITE.com User-Agent: Mozilla/5.0 (Macintosh; U; Intel Mac OS X 10.6; en-US; rv:1.9.2.12) Gecko/20101026 Firefox/3.6.6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,/;q=0.8 Accept-Language: en-us,en;q=0.5 Accept-Encoding: gzip,deflate Accept-Charset: ISO-8859-1,utf-8;q=0.7,*;q=0.7 Keep-Alive: 115 Proxy-Connection: keep-alive Content-Type: application/json; charset=utf-8 Referer: http://www.FAKESITE.com/profile.aspx?id=123BASE64VALUE456%3d%3d Cookie: SessionID=12345; Content-Length: 60

```
{"id": "123BASE64VALUE456==", "tag": "unicorns"}
```

'id' is a parameter that is unique to each user and never changes. The 'id' parameter is also viewable in the user's public profile URL.

'tag' is the value that the user enters in the text box on the profile view page. This value appears on both public and private profile pages, along with the list of tags that identify the user.

There is a character limit on the 'tag' value used in the text box form. But if the value is edited in a proxy, the limit is not enforced on the reflection; however, in order for our attack to be persistent, the 'tag' value must be within the character limit.

An example test injection that fits the character limit would be "<script>alert(1);//" because it will comment everything else out until a native </script> tag occurs in the html. This is a simple injection, in order to stay within the character limit.

A successful proof of concept where this injection would fit the character limit would be to call out to an external short URL. For example, wh.ly (not a real domain). In the PoC I made the home path a javascript file to limit the length of the injection. This allowed calling a large js command via a small injection.

If a short URL is not available, another technique that has proven successful is daisy-chaining the 'tag' words together by starting and ending the injection with block comment HTML delimiters '<--' and '-->'.

The injection reflects in the DOM-generated source, rather than on the native profile page's html.

Generated Source reflection area:

```
<div id="tagWords" style="display: inline;"> <div>Profile Tags:</div> <div id="divULTagWords">
<ul id="ulTagWords"> <li id="0">*<script>alert(1);//****</script>*</li></ul> </div> </div>
```

Now here's the nasty part of this method's capabilities:

The 'id' parameter in the POST request above can be altered to other base64 values that are easily found in the public profile URL of other users. When a request is submitted with a value that is considered a "valid" Tag Word, that tag is then persistently placed on the profile DOM of another user.

Because I was able to call an external javascript file in this injection, I could rather quickly – and without authorization – write a large script that would scrub urls for this base64 value and push malicious code onto the profile of every user.

I could then perform many unauthorized actions, ranging from the somewhat benign (add the keyword mattjayisawesome to every profile) to the very malicious (use known browser exploits, steal user sessions, reset passwords, etc.). And because this method of attack requires no user interaction in order

to infect every user on the site, and can also be self sustaining, it could be considered a wormable vulnerability.

Matt Johansen @mattjay Application Security Specialist WhiteHat Security, Inc.

Archived from <https://blog.whitehatsec.com/how-to-own-every-user-on-a-social-networking-site/>. Rendered offline from the local Markdown copy.